Pendik İTO Ticaret Mesleki ve Teknik Anadolu Lisesi

PİTO EduBounty

Güvenli KOBİ, Güvenli Gelecek

Meslek Öğretmeni & KOBİ Tanıtım Rehberi

Projenin Amacı	Kimler Yürütüyor?	KOBİ'ye Ne Kazandırır?
Öğrenciler KOBİ'lerin güvenlik açıklarını etik kurallara uygun biçimde tespit eder.	Bilişim teknolojileri öğrencileri, rehber öğretmen gözetiminde.	Ücretsiz siber güvenlik testi, detaylı güvenlik raporu.

Proje Dönemi: 2025 – 2029	**Proje Türü:** Okul Gelişim Projesi	**Hazırlayan:** Proje Koordinatörü

Bu rehber iki amaca hizmet eder: (1) Proje koordinatörü meslek öğretmenlerine projeyi aktarır. (2) Meslek öğretmenleri aynı dokümanla staj işletmelerine tanıtım yapar.

İÇİNDEKİLER

1. Siber Güvenlik Nedir? — Temel Kavramlar
2. KOBİ'ler Neden Hedef Alınır?
3. Bug Bounty Nedir? Nasıl Çalışır?
4. PİTO EduBounty Projesi — Genel Bakış
5. Öğrencilerimiz Ne Yapıyor? Nasıl Hazırlandılar?
6. KOBİ'ye Sunulan Hizmet: Adım Adım Süreç
7. KOBİ için Faydalar ve Güvenceler
8. Sıkça Sorulan Sorular (SSS)
9. Nasıl Başvurulur? — Sonraki Adımlar

1. Siber Güvenlik Nedir? — Temel Kavramlar

Siber güvenlik; bilgisayar sistemlerini, ağları, verileri ve yazılımları yetkisiz erişim, saldırı veya hasara karşı koruma bilimidir. Günümüzde her işletme dijital sistemlere bağımlı hale geldiğinden, siber güvenlik artık yalnızca büyük şirketlerin değil, **küçük işletmelerin de birincil sorunu** haline gelmiştir.

Bilmeniz Gereken Temel Kavramlar

Güvenlik Açığı (Vulnerability)	Bir yazılım veya sistemdeki, saldırganların istismar edebileceği zayıf nokta. Örneğin: eski bir WordPress teması, zayıf parola politikası.
Sızma Testi (Penetration Test)	Yetkili uzmanların sisteme sanki saldırgan gibi davranarak gerçek açıkları bulmaya çalıştığı kontrollü test.
Bug Bounty	İşletmenin, sistemindeki açıkları bulan etik araştırmacılara ödül verdiği program. Büyük firmalarda ücretli, bizim modelimizde eğitim amaçlı ücretsiz. Sadece açık bulunduğunda öğrencilere para ödülü veriliyor.
Etik Hacker	Sisteme zarar vermeden açık tespit eden, bulgularını sorumluluk bilinciyle raporlayan güvenlik uzmanı. Öğrencilerimiz bu role hazırlanmaktadır.
Sosyal Mühendislik	Teknik değil insan odaklı saldırı; sahte e-posta (phishing), telefon dolandırıcılığı gibi.
Veri İhlali (Data Breach)	Yetkisiz kişilerin müşteri, finans veya iş verilerine erişmesi. Türkiye'de KVKK kapsamında ciddi cezai yaptırımlara yol açar.

2. KOBİ'ler Neden Hedef Alınır?

Küçük ve orta ölçekli işletmeler, siber saldırıların **%43'ünün** hedefidir. Ancak bu işletmelerin yalnızca **%14'ü** kendini yeterince koruduğunu düşünmektedir. (Kaynak: Verizon DBIR 2023)

Neden Savunmasızlar?

- Büyük firmalara göre çok daha düşük güvenlik bütçesi
- Güncel olmayan yazılım ve sistemler
- Siber güvenlik çalışanı veya politikası yok
- Parola ve erişim yönetiminde zayıflık
- Çalışanların phishing farkındalığı düşük

Nelerle Karşılaşabilirler?

- Müşteri ve finansal verilere açık kapı
- Fidye yazılımı (ransomware) saldırısı riski
- Sahte fatura ve banka hesabı dolandırıcılığı
- E-ticaret sitesi üzerinden kart bilgisi çalınması
- KVKK ihlali nedeniyle idari ceza

Gerçek Dünyadan Örnekler

Küçük muhasebe firması	E-posta şifresini ele geçiren saldırgan, müşteri verilerini şifreleyerek 50.000 TL fidye istedi.
Online butik	Ödeme sayfasındaki açık üzerinden 3 ay boyunca kart bilgileri toplandı; sahip hiç fark etmedi.
Restoran zinciri	Rezervasyon sistemindeki SQL açığı sayesinde tüm müşteri listesi internete sızdı. KVKK cezası: 150.000 TL.

KOBİ sahibine söylenecek mesaj: 'Siber saldırı büyük şirketlere gelir' yanılgısı geçerliliğini yitirdi. Saldırganlar küçük işletmeleri tam da bu düşünce yüzünden hedef alıyor.

3. Bug Bounty Nedir? Nasıl Çalışır?

Bug bounty, bir şirketin kendi sistemlerini test etmeleri için güvenlik araştırmacılarını davet ettiği bir programdır. Google, Microsoft, Türk Hava Yolları gibi büyük firmalar yılda milyonlarca dolar harcayan bug bounty programları yürütmektedir. EduBounty modelimiz aynı mantıkla çalışır; fark şudur: **biz bunu ücretsiz ve eğitim odaklı yapıyoruz.**

Nasıl Çalışır? — Adım Adım

1	**Kapsam Belirleme** İşletme ile birlikte hangi sistemlerin test edileceği yazılı olarak belirlenir (web sitesi, e-posta altyapısı, açık ağ servisleri vb.). Kapsam dışına çıkılmaz.
2	**İzin Protokolü İmzalanması** Okul yönetimi, işletme sahibi ve proje koordinatörü arasında resmi bir izin belgesi imzalanır. Bu belge hem yasal güvence hem de etik çerçeve sağlar.
3	**Test Yapılması** Öğrenciler sanal ortamda ve belirlenen kapsam içinde sistemi test eder. Saldırı değil, açık arama yapılır. Veri okunmaz, değiştirilmez.
4	**Bulgular Raporlanır** Tespit edilen her açık öğretmen tarafından doğrulanır. Ardından açık, teknik olmayan bir dille işletmeye aktarılır.
5	**Kapatma Desteği** İşletme açıkları kapattıktan sonra isteğe bağlı doğrulama yapılabilir.

CTF (Capture The Flag) nedir? Öğrencilerimizin antrenman platformudur. Gerçek saldırı senaryoları simüle eden yarışmalar ve laboratuvar ortamları (**PortSwigger Web Academy** gibi) sayesinde öğrenciler gerçek sistemlere dokunmadan yetkinlik kazanır.

4. PİTO EduBounty Projesi — Genel Bakış

PİTO EduBounty – Güvenli KOBİ, Güvenli Gelecek, Pendik İTO Ticaret Mesleki ve Teknik Anadolu Lisesi tarafından yürütülen 4 yıllık bir Okul Gelişim Projesi'dir (2025–2029). Proje, bilişim teknolojileri öğrencilerinin siber güvenlik becerilerini **gerçek işletmeler** üzerinde uygulayarak hem mesleki yetkinlik kazanmalarını hem de bölgedeki KOBİ'lerin dijital güvenliğini artırmayı hedeflemektedir.

4 Yıllık Yol Haritası

Yıl	Dönem	Hedef
1. Yıl	2025–2026 Hazırlık	SiberLab kurulumu, öğrenci eğitimleri, bug raporlama portalının tasarımı
2. Yıl	2026–2027 Pilot	2 işletmeyle ilk güvenlik testi, portalın yayına alınması
3. Yıl	2027–2028 Genişleme	5 yeni işletme, Siber Güvenlik Haftası, mezun mentorlukları
4. Yıl	2028–29 Sürdürülebilirlik	Portalın kalıcılaşması, MEB'e yaygınlaştırma sunumu

Proje Ortakları ve Paydaşlar

Okulumuz	Pendik İTO Ticaret MTAL — Bilişim Teknolojileri ve Muhasebe Bölümleri
Üniversite	İstanbul Ticaret Üniversitesi — Akademik danışmanlık ve seminer desteği
Belediye	İlçe Belediyesi Bilgi İşlem Müdürlüğü — Pilot test ortamı
Altyapı	DigitalOcean — Bug raporlama portalı ve CTF uygulamaları için sunucu hizmeti
STK'lar	Siber güvenlik sivil toplum kuruluşları — Etik eğitim desteği

5. Öğrencilerimiz Ne Yapıyor? Nasıl Hazırlandılar?

KOBİ sahipleri zaman zaman 'lise öğrencisi ne kadar bilir?' diye sorabilir. Bu bölüm o soruyu yanıtlamak için hazırlanmıştır.

Öğrencilerin Eğitim Geçmişi — Gerçek Başarılar

- ✓ Teknofest Hackmasters finaline katılım: Öğrenciler 10. ve 13. sıra, öğretmen 5. sıra.
- ✓ THY gibi gerçek firmaların sistemlerinde bug tespiti (Hackmasters yarı finali).
- ✓ Liseler Arası CTF Yarışması: 1. yarışma 2.'lik, 2. yarışma 3.'lük.
- ✓ BayrakSende ulusal yarışması: Türkiye 4.'sü ve her yıl finale kalma.
- ✓ TSGKCTF 2026: Türkiye genelinde liseler arasında 2.lik
- ✓ BeingWise CTF: Türkiye genelinde 2.lik

Kullandıkları Eğitim Platformları

CTF (Capture The Flag) Yarışmaları	PicoCTF, HackTheBox, TryHackMe gibi platformlarda simüle edilmiş saldırı senaryoları çözerek teknik yetkinlik geliştirirler.
PortSwigger Web Academy	Dünyanın en önde gelen web güvenliği laboratuvar platformu. SQL enjeksiyonu, XSS, kimlik doğrulama açıkları gibi gerçek saldırı türlerini kontrollü ortamda öğrenirler. Tamamen ücretsiz ve sertifikalandırılabilir.
Akran Eğitimi	Üst sınıf ve mezun öğrenciler, alt sınıflara 10 günlük siber güvenlik eğitimi verir. Bu sayede hem öğreten hem öğrenen pekiştirir.

> **Öğretmen güvencesi:** Öğrenciler hiçbir zaman tek başına hareket etmez. Tüm testler proje koordinatörü (bilişim teknolojileri öğretmeni) gözetiminde yapılır. Her bulgu öğretmen onayından geçmeden işletmeye iletilmez.

6. KOBİ'ye Sunulan Hizmet: Adım Adım Süreç

İşletme sahibinin zihnindeki en büyük soru şudur: 'Sürece dahil olursam ne olur?' Aşağıdaki akış tüm aşamaları net biçimde göstermektedir.

1	**Tanışma ve Bilgilendirme Görüşmesi** Meslek öğretmeni işletme yetkilisiyle yüz yüze görüşür. Projenin kapsamı, yasal çerçevesi ve faydaları anlatılır. İşletmenin soruları yanıtlanır. Herhangi bir taahhüt yoktur.
2	**Kapsam ve İzin Belgesi** İşletme katılmaya karar verirse, hangi sistemlerin test edileceği birlikte belirlenir. Okul-işletme izin protokolü imzalanır. Kapsam dışına kesinlikle çıkılmaz.
3	**Teknik Hazırlık** Öğrenciler belirlenen sistemi test öncesi pasif keşif yöntemiyle analiz eder. Test planı koordinatör onayıyla şekillenir.
4	**Güvenlik Testi** Kontrollü ortamda, yasal sınırlar içinde test gerçekleştirilir. Veri okunmaz, değiştirilmez, silinmez. Sadece 'bu kapıdan girilebilir mi?' sorusu sorulur.
5	**Raporlama** Tespit edilen açıklar, teknik karmaşıklığı ne olursa olsun işletme sahibinin anlayacağı sade bir dille raporlanır. Raporda açıklama, risk seviyesi ve önerilen çözüm yer alır.
6	**Kapanış ve Takip** İşletme açıkları kapattıktan sonra isteğe bağlı doğrulama yapılabilir. Tüm süreç kayıt altına alınır, proje portalına eklenir.

İşletme sahibine söylenecek: *'Bu süreçte açık bulunmadığı müddetçe size hiçbir maliyet yüklenmez. Sistemlerinize zarar verilmez. Açık bulunan bulgularda ise öğrencilerimizi anlaşılan miktarlarda ödüllendirmeniz beklenmektedir. En önemli beklentimiz, tespit ettiğimiz açıkların kapatılması için samimi bir çaba göstermeniz.'*

7. KOBİ için Faydalar ve Güvenceler

Kazanımlar	Güvenceler
• Uygun maliyetli profesyonel güvenlik testi • Anlaşılır dilde yazılmış güvenlik raporu • Açıkların kapatılmasında teknik rehberlik • KVKK uyumu için farkındalık artışı • Müşteri ve çalışan verilerinin korunması • Yerel okul-sanayi iş birliğine katkı	• Yazılı izin protokolü — her aşama belgelenmiş • Öğrenciler öğretmen gözetiminde çalışır • Kapsam dışına çıkılmaz, veri alınmaz/değiştirilmez • Gizlilik taahhüdü — bulgular yalnızca işletmeyle paylaşılır • Okul yönetimi sürecin tüm sorumluluğunu üstlenir • Resmi yazışma ve protokol desteği

KVKK ve Hukuki Boyut

Türkiye'de Kişisel Verilerin Korunması Kanunu (KVKK) kapsamında, kişisel veri içeren sistemlerde yaşanan güvenlik ihlalleri **72 saat içinde bildirim** yükümlülüğü doğurur ve **1.000.000 TL'ye kadar idari para cezasına** yol açabilir. Proaktif bir güvenlik testi, bu riskleri önceden tespit ederek işletmeleri hukuki yaptırımlardan korur.

> **Gerçekçi bir beklenti yönetimi:** Tüm işletmelerde mutlaka kritik açık bulunacağı garanti edilemez. Bazı sistemler zaten iyi korunmuş olabilir. Ama 'hiçbir şey bulunamadı' raporu da işletme için değerli bir güvencedir.

8. Sıkça Sorulan Sorular (SSS)

Aşağıdaki sorular KOBİ sahiplerinin tanıtım görüşmelerinde en sık sorduğu sorulardır. Her biri için hazır yanıtınız olsun.

SORU	YANIT
Verilerimize erişecekler mi?	Hayır. Testler yalnızca sistemin dışarıdan erişilebilir yüzeylerine (web sitesi, açık servisler) yönelik yapılır. Veritabanı içerikleri, müşteri bilgileri, finansal kayıtlar kesinlikle görülmez.
Ya bir şey bozulursa?	Tüm testler üretim (canlı) sisteme minimum etkiyle tasarlanır. Yüksek risk taşıyan testler yalnızca işletmenin onayıyla ve mümkünse test ortamında yapılır. Tüm süreç kayıt altındadır.
Öğrencilere güvenebilir miyiz?	Öğrencilerimiz bu projeye dahil olmadan önce etik hacking, KVKK ve sorumluluk bilinci eğitimi alır. Rehberlik servisimiz bu eğitimleri yürütür. Tüm işlemler okul yönetiminin resmi güvencesi altındadır.
Ne kadar sürer?	1 Yıl. (Her yıl protokoller yenilenebilir.)
Rakiplerimiz bu bilgilere ulaşabilir mi?	Bulgular yalnızca sizinle paylaşılır. Proje portalımızdaki yayınlar tamamen anonimleştirilmiştir; işletme adı veya tanımlayıcı bilgi kesinlikle paylaşılmaz.
Katılım için ne yapmalıyız?	Meslek öğretmeninizle ikinci bir görüşme talep etmeniz yeterlidir. Sonrasında kapsam formu ve izin belgesi imzalanarak sürece başlanır. Herhangi bir aşamada geri çekilebilirsiniz.

9. Nasıl Başvurulur?

Proje şu an **hazırlık dönemindedir (2025-2026)**. Resmi KOBİ testleri **2026-2027 eğitim-öğretim yılında** başlayacaktır. Ancak işletmelerin şimdiden bilgi alması ve listeye eklenmesi, pilot sürece öncelikli dahil olmalarını sağlar.

İlk Adım: Ücretsiz Tanıtım Görüşmesi

Görüşmede size anlatacaklarımız:

- ✓ Projenin tam kapsamı ve 4 yıllık planı
- ✓ İmzalanacak izin protokolünün detayları
- ✓ Hangi sistemlerinizin test edilebileceği
- ✓ Daha önce yaptığımız çalışmalardan örnekler
- ✓ Sorularınızın tamamına yanıt

10. İletişim

Sizi Kim Arayacak?

Okulumuzdaki meslek öğretmenleri, staj koordinasyonu kapsamında düzenli olarak işletmelerle iletişim halindedir. Projeye ilgi duyuyorsanız, sizi ziyaret eden meslek öğretmenimize bildiriniz. Proje koordinatörümüz sizinle doğrudan iletişime geçer.

İletişim

Pendik İTO Ticaret Mesleki ve Teknik Anadolu Lisesi

Güzelyalı Mah. Sahil Yolu Cad. No:183 Pendik / İSTANBUL

E-posta: pitoedubounty@gmail.com

Okul Sitesi: pendikito.meb.k12.tr

Instagram: @pitoedubounty | @pendikitomtal

LinkedIn: linkedin.com/in/pito-edubounty

Bu projeye dahil olarak hem kendi işletmenizi daha güvenli hale getirirsiniz hem de bölgemizin geleceğini inşa eden gençlere katkı sağlarsınız.